

SCA Demonstration on a Sample Project Using FOSSA

Aim

To perform Software Composition Analysis (SCA) on a sample Node.js project using the FOSSA CLI, identify vulnerabilities in open-source dependencies, and generate a Software Bill of Materials (SBOM) in SPDX and SPDX-JSON formats.

Tools Required

- Kali Linux / Ubuntu Linux
- Internet connection
- Node.js and npm
- curl
- FOSSA CLI
- FOSSA account and FOSSA API key
- Sample Node.js project
- Terminal

Procedure

1. Update the package repository

```
sudo apt update
```

2. Install curl

```
sudo apt install -y curl
```

3. Install Node.js

```
curl -fsSL https://deb.nodesource.com/setup_22.x | sudo -E bash -  
sudo apt install -y nodejs
```

Alternatively:

```
sudo apt install curl nodejs npm -y
```

4. Install FOSSA CLI

```
curl -H 'Cache-Control: no-cache' \  
https://raw.githubusercontent.com/fossas/fossa-cli/master/install-latest
```

5. Verify the FOSSA installation

```
fossa --version
```

6. Configure the FOSSA API key

Obtain the API key from the FOSSA website and configure it in the terminal:

```
export FOSSA_API_KEY="YOUR_API_KEY"
```

7. Create a sample project directory

```
mkdir fossa-lab  
cd fossa-lab
```

8. Initialize a Node.js project

```
npm init -y
```

This creates a package.json file for the project.

9. Install a sample open-source dependency

```
npm install lodash@4.17.20
```

This adds Lodash as a dependency and creates the node_modules directory and package-lock.json.

10. Perform FOSSA analysis

```
fossa analyze
```

FOSSA analyzes the project's dependencies and sends the dependency information to the FOSSA platform.

11. Run the FOSSA dependency test

```
fossa test
```

This checks the project's dependencies against FOSSA's vulnerability and license policies.

12. Generate an SPDX attribution report

```
fossa report attribution --format spdx
```

13. Save the SPDX SBOM to a file

```
fossa report attribution --format spdx > sbom-spdx.txt
```

14. Generate an SPDX JSON SBOM

```
fossa report attribution --format spdx-json > sbom-spdx.json
```

15. Verify the generated files

```
ls -lh
```

16. Display the SPDX SBOM

```
cat sbom-spdx.txt
```

17. Display the SPDX-JSON SBOM

```
cat sbom-spdx.json
```

Result / Output

The sample Node.js project was successfully analyzed using the FOSSA SCA tool. The project's open-source dependency, Lodash 4.17.20, was identified and analyzed for security vulnerabilities and license information.